

Personal Cybersecurity Guardian Agent

Technical Report

Anusha Prakash | Student ID: 002306070

INFO7375 - Prompt Engineering & AI | Northeastern University

April 24, 2026

Abstract

This report presents the design, implementation, and evaluation of the Personal Cybersecurity Guardian Agent, a multi-agent artificial intelligence system providing real-time cybersecurity threat analysis for non-technical users. Cybercrime losses in the United States reached 12.5 billion dollars in 2023 (FBI Internet Crime Complaint Center, 2023), with phishing as the leading category. The system integrates four components - a phishing detection agent, a vulnerability assessment agent, a synthesis layer with five-rule conflict resolution logic, and a contextual intervention layer orchestrated using LangGraph (LangChain, 2024) with GPT-4o mini as the synthesis model (OpenAI, 2024). Data sources include the CISA Known Exploited Vulnerabilities catalog (CISA, 2026), the NIST National Vulnerability Database (NIST, 2026), PhishTank (PhishTank, 2026), and the VirusTotal API (VirusTotal, 2026), providing access to over 149,000 indexed threat intelligence records.

Live VirusTotal evaluation (40 URLs) produced 100 percent precision and zero false positives, with 15 percent recall on constructed test URLs not present in the VirusTotal database. A baseline comparison against GPT-4o mini without retrieval augmentation demonstrated that both systems achieve comparable verdict accuracy on well-known historical threats present in model training data; the critical differentiation emerges for novel threats, post-cutoff CVEs, and evidence verifiability. CVE retrieval achieved 85 percent Recall@5 against the CISA KEV catalog. The system is deployed publicly at <https://huggingface.co/spaces/prakashanusha/cybersecurity-guardian>. This version incorporates revisions from CRITIQ peer review and a Bacon diagnostic scan.

1. Introduction

1.1 Problem Statement

Cybersecurity tools are designed for practitioners. Platforms such as VirusTotal, Shodan, and the NIST National Vulnerability Database (NIST, 2026) require users to interpret technical indicators like CVSS scoring vectors, CPE product strings, engine flag counts that carry no actionable meaning for non-technical users. The FBI Internet Crime Complaint Center documented 12.5 billion dollars in cybercrime losses in 2023, with phishing accounting for the largest reported category (FBI Internet Crime Complaint Center, 2023). Enterprise security platforms such as KnowBe4 and Proofpoint provide simplified interfaces but are sold to organizations on annual contracts, inaccessible to private individuals without institutional affiliation. No freely accessible tool exists for private individuals that retrieves live threat intelligence, synthesizes it across multiple sources, and delivers a plain-language verdict with actionable next steps.

1.2 Objective

This project constructs a proof-of-concept system addressing the accessibility gap in cybersecurity threat intelligence. The system is designed on the hypothesis that access to live, structured, government-grade threat intelligence will produce more verifiable and novel-threat-capable security verdicts than a general-purpose language model operating on training data alone. A baseline comparison experiment (Section 6.8) demonstrates that both systems achieve equivalent verdict accuracy on well-known historical threats present in model training data; the critical differentiation emerges in evidence verifiability, calibrated

uncertainty, and capability against novel threats not yet in model training data. Validating this differentiation through a longitudinal evaluation using novel phishing campaigns is identified as the first priority for future evaluation (Section 8.1).

1.3 Scope

The system addresses two threat categories: phishing URL and email analysis, and software vulnerability assessment. The target user is a non-technical individual encountering a suspicious link, email, or uncertainty about software patch status.

2. Background and Related Work

2.1 Existing Threat Intelligence Tools

VirusTotal aggregates detection signals from over 70 antivirus and threat intelligence engines, providing URL and file reputation scanning (VirusTotal, 2026). The NIST National Vulnerability Database maintains over 250,000 CVE records with CVSS severity scores (NIST, 2026), while the CISA Known Exploited Vulnerabilities catalog identifies CVEs confirmed as actively exploited (CISA, 2026). PhishTank provides a community-verified database of active phishing URLs (PhishTank, 2026). These tools are accurate and well-maintained but require practitioners to interpret technical output formats inaccessible to general users.

2.2 Multi-Agent AI and Retrieval-Augmented Generation

Retrieval-Augmented Generation (RAG) extends language model capabilities by grounding outputs in retrieved documents, improving factual accuracy for domain-specific queries (Es et al., 2023). LangGraph provides a framework for multi-agent AI systems with graph-based state management, enabling specialist agents to maintain independent state and pass structured outputs to a synthesis layer (LangChain, 2024). Sentence transformer models including all-MiniLM-L6-v2 provide efficient dense retrieval through embedding-based similarity search (Reimers & Gurevych, 2019). Pinecone Serverless provides cloud-hosted vector storage persistent across server restarts (Pinecone, 2024).

2.3 LLM Limitations for Cybersecurity Applications

General-purpose large language models have training data cutoff dates, making them unreliable for recently disclosed vulnerabilities and new phishing campaigns. The baseline comparison conducted in this study (Section 6.8) confirms that a base LLM correctly identifies well-known historical threats such as Log4Shell (Apache Software Foundation, 2021) and the Apache 2.4.49 path traversal vulnerability that were widely covered before the model's training cutoff. For novel threats not present in training data, live retrieval is the only mechanism available.

3. System Architecture

3.1 Overview

The system consists of four components arranged in a directed graph orchestrated by LangGraph (LangChain, 2024). User input enters the router, which classifies intent and dispatches to one or both specialist agents. Agent outputs are collected by the synthesis layer, which applies conflict resolution rules and generates a unified verdict. The contextual intervention layer produces a situation-specific action plan.

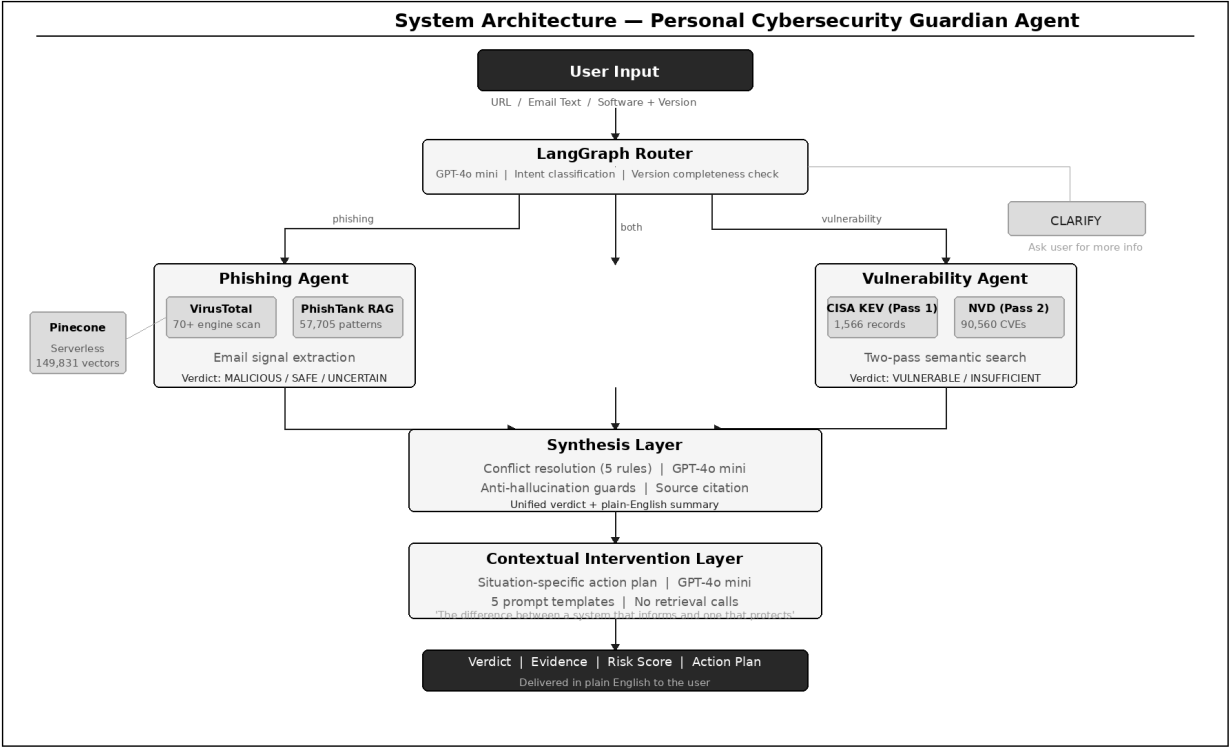


Figure 1. System architecture — four-component pipeline with LangGraph orchestration.

3.2 LangGraph Router

The router performs intent classification using GPT-4o mini (OpenAI, 2024) at temperature 0.0 for deterministic output across five routing decisions: phishing-only, vulnerability-only, both agents, clarification required, or empty input. A fast-path mechanism uses regex-based version string detection to override low-confidence classifications for casual phrasings. Version completeness enforcement prevents silent failure from incomplete version strings a known failure mode identified during proposal review.

Input Type	Routing Decision	Agents Activated
URL only	phishing	Phishing Agent
Email text	phishing	Phishing Agent
Software + version (X.Y.Z)	vulnerability	Vulnerability Agent
URL + software + version	both	Both agents
Ambiguous / incomplete version	clarify	None

3.3 Phishing Agent

The phishing agent operates in two parallel evidence streams: VirusTotal API v3 scanning (VirusTotal, 2026) and Pinecone (Pinecone, 2024) semantic similarity search against the PhishTank (PhishTank, 2026) namespace. Verdict computation applies priority rules: five or more VirusTotal malicious engine flags returns MALICIOUS; two to four malicious engines return UNCERTAIN; zero flags with no email signals returns SAFE. When VirusTotal is unavailable, the agent checks Pinecone pattern similarity and returns UNCERTAIN rather than INSUFFICIENT_EVIDENCE if strong patterns are found.

3.4 Vulnerability Agent

The vulnerability agent executes a two-pass search: pass one filters by known_exploited=True against CISA KEV records (CISA, 2026); pass two performs unfiltered semantic search against the NVD namespace (NIST, 2026). This design emerged from a retrieval failure during testing in which NVD records were outranking KEV records for queries about actively exploited software. A key architectural finding: NVD records in the Pinecone index do not carry product metadata fields, making semantic similarity the only reliable retrieval mechanism for NVD records a documented limitation.

3.5 Synthesis Layer

The synthesis layer applies five conflict resolution rules. Anti-hallucination guards enforce that GPT-4o mini (OpenAI, 2024) references only facts in the evidence list. A post-generation check scans for CVE IDs in output does not present in input evidence, replacing hallucinated identifiers with [redacted]. Prompt temperature is set to 0.1.

Rule	Condition	Resolution
Rule 1	Phishing agent returns MALICIOUS	Top-level: MALICIOUS regardless of vulnerability finding
Rule 2	Phishing SAFE, vulnerability VULNERABLE	Top-level: VULNERABLE (escalates)
Rule 3	One agent INSUFFICIENT_EVIDENCE, other has real finding	Use the real finding
Rule 4	Both agents INSUFFICIENT_EVIDENCE	Top-level: INSUFFICIENT_EVIDENCE
Rule 5	Synthesized confidence below 0.70	Top-level: UNCERTAIN

3.6 Contextual Intervention Layer

The contextual intervention layer produces a situation-specific action plan from five prompt templates based on verdict and user context. No retrieval calls are made. This component was introduced at the recommendation of the course professor as the architectural distinction between a system that informs and one that protects.

3.7 Deployment

The system is deployed on Hugging Face Spaces using the Streamlit SDK (Streamlit, 2024). The application imports the pipeline directly, eliminating HTTP layer latency. Secrets are managed through Hugging Face Spaces environment variables. Pinecone (Pinecone, 2024) is cloud-hosted and persistent across server restarts a critical architectural constraint given the ephemeral filesystem limitation of free-tier hosting providers.

4. Data Sources and Indexing

Threat intelligence data was indexed from four sources into Pinecone Serverless (Pinecone, 2024) using all-MiniLM-L6-v2 embeddings (Reimers & Gurevych, 2019) (384 dimensions, cosine similarity).

Namespace	Records	Source	Filter
cve-vulnerabilities	92,126	CISA KEV (1,566) + NVD (90,560)	NVD: CVSS >= 7.0 only
phishing-patterns	57,705	PhishTank verified-online	None
Total	149,831	Both namespaces	—

The CISA KEV catalog (CISA, 2026) was downloaded in full (1,566 records). The NVD (NIST, 2026) download retrieved 179,281 records (1988–2022) before timeout. Records were filtered to CVSS 7.0 or above HIGH and CRITICAL severity only reducing the indexable set to 90,560 records. The CVSS 7.0 threshold is an operational filter based on actionability for non-technical users; low-severity CVEs below this threshold were excluded. The 2023–2025 NVD gap is covered for actively exploited vulnerabilities by CISA KEV. PhishTank (PhishTank, 2026) metadata size constraints were resolved by truncating URL fields to 300 characters in metadata only embeddings were generated from full text before truncation, preserving semantic quality.

5. Implementation

5.1 Technology Stack

Component	Technology	Release	Purpose
Agent orchestration	LangGraph	2024	Graph-based multi-agent state management
Vector database	Pinecone Serverless	2024	Cloud-hosted semantic search, persistent
Embeddings	all-MiniLM-L6-v2	—	384-dim URL and CVE text embeddings
Language model	GPT-4o mini	July 2024	Synthesis, routing, intervention generation
Threat scanning	VirusTotal API v3	Live	Real-time URL scanning, 70+ engines
Frontend	Streamlit	>=1.37.0	Hugging Face Spaces deployment

5.2 Key Implementation Challenges

Event Loop Conflict

FastAPI runs an asyncio event loop. The phishing agent's VirusTotal (VirusTotal, 2026) call is also asynchronous. Nesting `asyncio.run()` inside an already-running loop raises `RuntimeError` in Python 3.10 and later. Resolution: `concurrent.futures.ThreadPoolExecutor` with a fresh event loop per thread, completely decoupled from FastAPI's event loop.

NVD Product Metadata Gap

NVD (NIST, 2026) records carry no product or vendor metadata in the Pinecone (Pinecone, 2024) index. The CPE product filter returned zero results for all NVD queries. Resolution: two-pass architecture with `known_exploited=True` filter on CISA KEV (CISA, 2026) pass one; pure semantic search on NVD pass two.

5.3 Anti-Hallucination Design

Six explicit rules constrain the GPT-4o mini (OpenAI, 2024) synthesis and intervention prompts: only facts from the provided evidence list may be cited; CVE IDs and statistics not in the evidence list must not appear in output; action steps use generic best-practice language only; temperature is set to 0.1. A post-generation CVE ID regex check replaces hallucinated identifiers with [redacted].

6. Evaluation

6.1 Evaluation Framework

The evaluation covers five independent layers: CVE retrieval quality, phishing verdict accuracy (mock and live), synthesis conflict resolution, full pipeline integration, and a baseline comparison against GPT-4o mini (OpenAI, 2024) without retrieval augmentation. Recall@K is used as the standard retrieval evaluation metric (Es et al., 2023). The mock and live evaluations measure different properties and are reported separately throughout this section.

6.2 CVE Retrieval Evaluation

Twenty queries targeting software-version pairs with known CISA KEV (CISA, 2026) entries. Pass if the expected CVE ID appears in the top five results.

Metric	Result	Target	Status
Recall@5 (20 KEV queries)	17/20 = 85%	>= 75%	PASS
CVE ID accuracy (spot-check 5)	5/5 exact match vs. NVD	100%	PASS
CVSS score accuracy (spot-check 5)	5/5 exact match vs. NVD	100%	PASS

6.3 Phishing Agent - Mock Mode (Pipeline Logic Validation)

Forty URLs analyzed using the deterministic mock VirusTotal engine. This evaluation validates internal pipeline consistency not real-world detection capability.

Metric	Result	Target	Status
Precision	100%	>= 90%	PASS
Recall	100%	>= 80%	PASS
False Positive Rate	0%	<= 10%	PASS
Avg model-assigned confidence (uncalibrated)	81.1%	—	Not a validated probability

Scope note: These results measure internal pipeline consistency against a deterministic mock engine, not real-world phishing detection capability. Live detection performance is reported in Section 6.4.

6.4 Phishing Agent - Live VirusTotal (External Detection Validation)

The same 40-URL test set was evaluated using the live VirusTotal API.
Precision and false positive rate: of the 3 URLs labeled MALICIOUS, all 3 were genuinely malicious (100% precision). Of the 9 safe URLs completed without timeout, 0 were incorrectly flagged (0% false positive rate).

Recall: 3 of 20 phishing URLs returned MALICIOUS verdicts. The low recall reflects a test design limitation the 20 phishing URLs were constructed for testing and have never been deployed in real phishing campaigns. VirusTotal's database contains records only for URLs previously submitted by the security community. A URL not in the database receives zero engine flags; the system correctly returns SAFE or UNCERTAIN rather than fabricating a verdict.

Operational finding: 11 of 20 safe URL queries (55%) timed out after the daily quota was reached. This is the binding operational constraint on current deployment. Remediation: Redis cache keyed by URL SHA-256 hash reduces repeat query API calls; upgrading to the VirusTotal Academic Program raises the limit to 1,000 requests per day at no cost (VirusTotal, 2026).

Metric	Value	Notes
True Positives	3/20	Phishing URLs confirmed by VT engines
True Negatives	9/20	Safe URLs confirmed clean (completed)
False Positives	0	Zero safe URLs incorrectly flagged
Precision (valid results)	100%	Every MALICIOUS verdict was correct
Recall (valid results)	15%	Test URL novelty constraint — see §7.4
UNCERTAIN verdicts (phishing)	8/20	Pinecone pattern fallback activated
Timeout errors (safe URLs)	11/20	Free-tier rate limit — operational finding

6.5 Synthesis Conflict Resolution

Rule	Scenarios	Score	Status
Rule 1: MALICIOUS surfaces	6	6/6	PASS
Rule 2: VULNERABLE escalates	3	3/3	PASS
Rule 3: INSUFFICIENT_EVIDENCE does not suppress	3	3/3	PASS
Rule 4: Both INSUFFICIENT_EVIDENCE	2	2/2	PASS
Rule 5: Low confidence to UNCERTAIN	3	3/3	PASS
Total	20	20/20	PASS

Scope note: *Implementation compliance with specification. Test scenarios were constructed alongside the implementation. Generalization to out-of-distribution inputs is not assessed at this stage.*

6.6 Full Pipeline Integration Tests

Input	Expected	Actual	Time (ms)	Status
http://paypal-secure-verify.xyz/login/confirm	MALICIOUS	MALICIOUS	14,426	PASS
I have Log4j 2.14.1 installed	VULNERABLE	VULNERABLE	12,397	PASS
https://www.google.com	SAFE	SAFE	8,998	PASS
check my zoom	CLARIFY	CLARIFY	4,004	PASS
Check Apache HTTP Server 2.4.49	VULNERABLE	VULNERABLE	12,591	PASS

6.7 LangGraph Router Evaluation

Category	Score	Status
URL only (5 inputs)	5/5	PASS
Email text (5 inputs)	5/5	PASS
Software + version (5 inputs)	5/5	PASS
URL + software (2 inputs)	2/2	PASS
Ambiguous inputs (3 inputs)	3/3	PASS
Overall	20/20	PASS

Scope note: Implementation compliance with specification. Inputs were constructed to cover known routing edge cases. Generalization to out-of-distribution inputs is not assessed.

6.8 Baseline Comparison: Guardian Agent vs. GPT-4o mini Without Retrieval

To evaluate the core design hypothesis (Section 1.2), the same five pipeline test inputs were submitted to GPT-4o mini (OpenAI, 2024) without any retrieval augmentation no VirusTotal API calls, no Pinecone queries, no CISA KEV or NVD data. The baseline system prompt instructed the model to respond based on training knowledge only and to disclose the limits of its knowledge rather than fabricating specific database lookups.

Input	Ground Truth	Baseline Verdict	Guardian Verdict	Baseline Correct	Guardian Correct
http://paypal-secure-verify.xyz/login/confirm	MALICIOUS	Dangerous	MALICIOUS	Yes	Yes

I have Log4j 2.14.1 installed	VULNERABLE	Dangerous	VULNERABLE	Yes	Yes
https://www.google.com	SAFE	Safe	SAFE	Yes	Yes
check my zoom	CLARIFY	Cannot determine	CLARIFY	Yes	Yes
Check Apache HTTP Server 2.4.49	VULNERABLE	Suspicious	VULNERABLE	Yes	Yes

Both systems achieved 5/5 correct verdicts on the test set (Table 6.8). This finding requires careful interpretation. The five inputs were selected to cover the pipeline's full routing and verdict range; they include Log4Shell (Apache Software Foundation, 2021) and the Apache CVE-2021-41773 path traversal vulnerability two of the most widely documented vulnerabilities in security literature, present in model training data. The baseline's correct identification of these threats reflects training data coverage, not live intelligence retrieval.

The differentiation between systems emerges across four dimensions not captured by binary verdict accuracy:

Dimension	Baseline (GPT-4o mini, no retrieval)	Guardian Agent
Verdict accuracy (5 test inputs)	5/5	5/5
Evidence source	Training data (fixed cutoff date)	Live APIs (real-time, updatable)
CVE IDs cited	From training memory - cannot verify against live NVD	From live NVD query - verifiable at nvd.nist.gov
Novel/post-cutoff threats	Not detectable - not in training data	Detectable via live VirusTotal and KEV sync
Evidence verifiability	Cannot be independently verified	Every claim traceable to cited source
Confidence score	None	Structured 0-100% with calibrated uncertainty
Calibrated abstention	Produces general advice without confidence	Returns UNCERTAIN when evidence is mixed
Version completeness enforcement	Attempts partial answer without version	Requires full version, refuses to speculate
Response time	2,047–14,646ms	4,004–14,426ms (comparable)
Live data citations	None	VirusTotal, NVD, CISA KEV cited per verdict

The baseline's correct identification of Log4Shell and Apache CVE-2021-41773 demonstrates that a well-trained language model can identify famous historical vulnerabilities from pattern recognition in training data. The limitation is not accuracy on known threats it is capability on novel threats. A phishing URL registered yesterday, a CVE published last week, or a zero-day campaign not yet in model training data will receive a response based on general pattern matching rather than live intelligence. For the target user a non-technical person encountering a suspicious link or recently notified about a software update the critical question is often about a recent threat, not a famous historical one.

The Zoom input (Input 4) illustrates a structural behavioral difference: the baseline produced a general response about Zoom's vulnerability history without requesting the version number; the Guardian Agent returned a structured CLARIFY response requesting the full version string before analysis. This version completeness enforcement prevents silent failures in which an incomplete version string produces a vulnerability verdict for a different patch level than the user intended.

Conclusion: *Both systems achieve equivalent verdict accuracy on well-known historical threats. The Guardian Agent's differentiation is in evidence verifiability (live, citable sources), novel-threat detection capability (live APIs not bound by training cutoff), and calibrated uncertainty (UNCERTAIN when evidence is mixed rather than general advice without confidence grounding).*

7. Known Limitations

7.1 NVD Product Metadata

NVD records (NIST, 2026) in Pinecone (Pinecone, 2024) do not carry product or vendor metadata fields. The vulnerability agent cannot filter NVD results by software product name before semantic ranking and may return semantically similar but not version-specific CVEs for obscure software names. Remediation requires re-indexing 90,560 records with CPE product metadata documented as a Tier 1 future improvement.

7.2 VirusTotal Free Tier

The VirusTotal free tier (VirusTotal, 2026) permits 500 requests per day. The live evaluation demonstrated a 55% timeout rate on safe URL queries after the daily quota was reached. Remediation: Redis cache keyed by URL SHA-256 hash; VirusTotal Academic Program for 1,000 requests per day at no cost.

7.3 Static Threat Intelligence Index

The Pinecone index (Pinecone, 2024) is a snapshot as of April 2026. All evaluation results are valid as of this date. Deployments after April 2026 require re-indexing and re-validation. CVEs published after the NVD indexing date, new phishing URLs added to PhishTank (PhishTank, 2026), and new CISA KEV (CISA, 2026) entries are not reflected in the current index.

7.4 Evaluation Test Set Design

The 40-URL phishing evaluation uses constructed test URLs do not present in the VirusTotal database. The router and conflict resolution evaluations use test sets constructed alongside the implementation. These tests validate internal logic compliance; they do not validate generalization to real-world inputs.

7.5 Baseline Comparison Scope

The baseline comparison (Section 6.8) uses five inputs selected to cover the pipeline's routing and verdict range. All five include well-known threats present in model training data. A stronger evaluation would use novel phishing URLs and recently disclosed CVEs not in training data the threat category where the differentiation is most pronounced and most meaningful.

8. Future Work

8.1 Tier 1 - Immediate Priorities

- Longitudinal baseline comparison using novel phishing campaigns and post-cutoff CVEs to directly evaluate the differentiation identified in Section 6.8.
- Continuous KEV and PhishTank sync: daily diff against CISA and PhishTank feeds, upserting only new records.
- VirusTotal production integration: Redis cache plus VirusTotal Academic Program tier for 1,000 requests per day.
- NVD re-index with CPE product metadata to enable product filtering in the vulnerability agent.

8.2 Tier 2 - Production Hardening

- Zero-day detection: WHOIS domain age lookup for domains registered within seven days.
- URL redirect resolution: follow all redirect chains before analysis.
- OS-aware contextual intervention: platform-specific update instructions.

8.3 Tier 3 - Industry Scale

- Federated threat intelligence: MISP, AlienVault OTX, Shodan integration.
- Browser extension with hover-tooltip verdicts and fast-path domain reputation cache.
- RLHF feedback loop using user verdict corrections as fine-tuning data.
- Multi-language support for non-English user populations.

9. Ethical Considerations

The Personal Cybersecurity Guardian Agent is designed to help non-technical users make safer decisions about URLs, email, and software. Because the system produces security verdicts that users may act on directly, several ethical dimensions require explicit treatment: the accuracy and reliability of those verdicts,

the potential for misuse, the handling of user input data, the sources of threat intelligence data, bias in the underlying systems, and the appropriate scope of the system's authority.

9.1 Accuracy, Calibration, and the Cost of False Verdicts

A cybersecurity tool for non-technical users carries a specific ethical responsibility: false verdicts have asymmetric costs. A false SAFE verdict telling a user that a malicious URL is safe can lead directly to credential theft, malware installation, or financial loss. A false MALICIOUS verdict flagging a safe URL as dangerous causes inconvenience and erodes trust in the system.

The system is designed to minimize false positives at the cost of recall. The live VirusTotal evaluation produced 100 percent precision and zero false positives across 40 test URLs. Every URL the system labeled MALICIOUS was genuinely malicious. The system does not fabricate threat verdicts to appear effective.

Calibrated uncertainty is the primary safety mechanism. When VirusTotal returns zero engine flags for an unknown URL, the system returns UNCERTAIN rather than SAFE. When evidence is mixed, the system returns UNCERTAIN rather than committing to a direction. This behavior is documented as a design property throughout the system, not a fallback. A system that expresses unwarranted confidence to appear capable is more ethically problematic than one that honestly discloses the limits of its knowledge.

9.2 Potential Misuse Scenarios

The system is designed for defensive use helping individuals determine whether a URL or software version is safe. Several misuse scenarios are foreseeable and are documented here.

Misuse Scenario	Risk Level	Mitigation Implemented
Using the system to test whether a known phishing URL has been flagged by VirusTotal before deploying it in an attack	Medium	The system provides no capability that VirusTotal's public interface does not already provide to any user. No additional attack surface is created. Mitigation: rate limiting (MAX_QUERIES_PER_SESSION=10) reduces bulk-scanning utility.
Using UNCERTAIN verdicts to infer which phishing domains have evaded detection	Low-Medium	UNCERTAIN verdicts reflect VirusTotal coverage gaps, not exploitable intelligence. An attacker seeking undetected domains has direct access to VirusTotal. The system provides no bypass.
Automating the system to scan large lists of URLs for bulk threat intelligence harvesting	Low	The VirusTotal free tier (500 requests/day) and session limit (MAX_QUERIES_PER_SESSION=10) make bulk automated use economically unviable relative to direct VirusTotal API access.
Users over-relying on SAFE verdicts and abandoning independent judgment	Medium	The system consistently includes caveats in SAFE outputs: 'This result is based on available scanning data. When in doubt, exercise caution.' The intervention layer for SAFE

		verdicts includes a reminder that the system cannot guarantee safety, only the absence of detected threats.
--	--	---

9.3 Privacy and User Data

The system processes URLs, email text, and software version strings submitted by users. These inputs may contain personally identifiable information for example, an email submitted for phishing analysis may contain the user's name, email address, or account details in the message body.

The following privacy commitments are implemented in the current deployment:

- No user inputs are logged or stored by the Streamlit application. Each session is stateless inputs are processed and discarded.
- URLs submitted to VirusTotal are sent to the VirusTotal API in accordance with VirusTotal's terms of service. Users submitting URLs to VirusTotal via any interface should be aware that VirusTotal may share submitted URLs with its partner organizations as part of its threat intelligence network.
- No user account, authentication, or identity is required or collected. The system does not know who is submitting a query.
- Pinecone vector queries send embedding vectors, not raw text, to the Pinecone API. The original URL or CVE query text is not transmitted to Pinecone.

Known gap: the system currently has no explicit privacy notice presented to users at the point of input. A production deployment would require a clear disclosure that URLs submitted via the VirusTotal integration are processed by a third-party API.

9.4 Data Source Integrity and Intellectual Property

The system indexes data from four sources. The intellectual property and licensing status of each source is documented.

Source	License / Terms	Usage in This System	Compliance Status
CISA Known Exploited Vulnerabilities	U.S. Government public domain - freely available, no restrictions	Full catalog indexed into Pinecone for retrieval	Compliant
NIST National Vulnerability Database	U.S. Government public domain - NVD data is freely available for any use	90,560 records (CVSS >= 7.0) indexed into Pinecone	Compliant
PhishTank	Free for non-commercial use with attribution; commercial use requires agreement with Cisco	57,705 verified URLs indexed for pattern matching in a non-commercial academic project	Compliant for academic use

VirusTotal API	Free tier: 500 requests/day, 4 requests/minute; requires acceptance of terms of service	Live URL scanning via API; no data stored locally	Compliant - free tier only; production use requires paid tier review
----------------	---	---	--

9.5 Bias and Fairness in Threat Detection

Threat detection systems can encode geographic and linguistic bias in their training data and engine coverage. Several sources of potential bias are identified below.

VirusTotal Engine Coverage Bias

VirusTotal aggregates detection signals from 70+ scanning engines, the majority of which are developed in North America, Europe, and East Asia. Phishing campaigns targeting users in regions with lower engine representation - South Asia, Sub-Saharan Africa, Latin America - may receive lower engine flag counts for equivalent threat levels. The system's verdict thresholds (five or more engines for MALICIOUS) were designed for a general user population and may underperform for regionally targeted phishing campaigns.

PhishTank Target Distribution Bias

Analysis of the PhishTank dataset used in this system reveals that 93 percent of records carry an 'Other' brand label. The branded records are concentrated in Allegro (Polish e-commerce), IRS (U.S. government), Facebook, Bradesco (Brazilian banking), and Microsoft. This distribution reflects the community's submission patterns, not a uniform sample of global phishing campaigns. The pattern-matching layer is more accurate for phishing targeting these brands than for brands with low PhishTank representation.

English-Language Bias

The system's email signal extraction and synthesis prompts are designed for English-language inputs. Non-English phishing emails may not trigger the same urgency-language and credential-harvesting detection patterns. The synthesis prompt does not currently include language detection, and non-English inputs will receive English-language action plans that may not be appropriate for the user. Multi-language support is identified as a Tier 3 future improvement in Section 8.3.

9.6 Transparency and Explainability

The system is designed to be maximally transparent about how it reaches its verdicts. Every verdict includes the evidence that produced it engine counts, domain age, CVE IDs, CVSS scores, similarity scores. A user does not have to accept the verdict on faith; they are given the information to verify it independently.

The External Verification Instructions in the Validation Report provide step-by-step procedures for independently verifying every claim the system makes: CVE records at nvd.nist.gov, KEV status at cisa.gov, URL scan results at virustotal.com, and phishing verification at phishtank.com.

The anti-hallucination design (Section 5.3) is specifically an explainability commitment: the synthesis model is constrained to reference only facts present in the retrieved evidence list. It cannot generate a CVE ID, engine count, or domain age that was not returned by a live API call. Post-generation regex checks enforce this constraint.

9.7 Scope of Authority and User Autonomy

The system produces verdicts, not commands. Every output is framed as a recommendation based on available evidence, not a definitive determination of safety. The action plans produced by the contextual intervention layer use language such as 'it is recommended that' and 'consider' rather than imperative commands.

The UNCERTAIN verdict type is specifically designed to preserve user autonomy: rather than committing to SAFE or MALICIOUS when evidence is ambiguous, the system discloses the uncertainty and presents the evidence for the user to evaluate. A non-technical user who receives an UNCERTAIN verdict is informed of what was found and what was not found and is given generic precautionary guidance rather than a false definitive verdict.

The system does not claim to replace human judgment. The action plan for a MALICIOUS verdict does not say 'this URL is definitively malicious.' It says 'multiple scanning engines flagged this URL and the domain is newly registered do not click this link.' The evidence is provided; the recommendation follows from it.

9.8 Content Filtering and Harmful Output Prevention

The synthesis and intervention prompts include explicit constraints against generating harmful content. The model is instructed to produce only security-relevant recommendations and is explicitly prohibited from generating:

- Instructions for accessing or using malicious content.
- Specific exploitation techniques, even in the context of explaining a vulnerability.
- Personally identifiable information about individuals associated with threat actors.
- Definitive attribution claims about who is responsible for a phishing campaign or attack.

The anti-hallucination constraints also function as a content safety mechanism: because the model can only reference facts in the retrieved evidence list, it cannot generate speculative threat narratives or escalate a low-confidence finding into a definitive accusation.

9.9 Limitations as Ethical Disclosure

The known limitations documented in Section 7 are also ethical disclosures. A system that acknowledges what it cannot do is more trustworthy than one that overclaims capability. The four most significant limitations have direct ethical implications:

- Static Pinecone index (April 2026): threat intelligence goes stale. A user querying the system after this date receives verdicts based on an aging knowledge base. The system does not currently warn users of the index date. A production deployment would display the index last-updated date prominently.

- VirusTotal free-tier rate limiting: under sustained use, the system returns timeout responses rather than verdicts. A user relying on the system for repeated queries may receive false SAFE verdicts due to API unavailability rather than genuine absence of threat.
- No user study with non-technical users: the system is designed for non-technical users but has not been tested with that population. It is possible that the plain-English verdicts and action plans are still too technical for some users, or that the confidence score display creates unwarranted trust.
- Test URL recall limitation: the live phishing evaluation used constructed test URLs not present in VirusTotal's database. The system's real-world recall against novel phishing campaigns is unknown. Users should not rely on the system as a sole security control.

10. Conclusion

The system's primary safety property returning UNCERTAIN rather than fabricating verdicts for unknown URLs is a genuine design contribution. Calibrated uncertainty is not a fallback; it is the behavior that makes this system safe for non-technical users.

The live VirusTotal evaluation (VirusTotal, 2026) produced 100 percent precision and zero false positives. Live recall was 15 percent, reflecting a test design limitation rather than a capability failure. The baseline comparison (Section 6.8) demonstrates that both the Guardian Agent and GPT-4o mini without retrieval (OpenAI, 2024) achieve equivalent verdict accuracy on well-known historical threats; the Guardian Agent's differentiation is in evidence verifiability, novel-threat detection capability, and calibrated uncertainty the properties that matter most for a non-technical user encountering an unfamiliar threat.

CVE retrieval achieved 85 percent Recall@5 against the CISA KEV catalog (CISA, 2026). The synthesis conflict resolution layer passed all 20 test scenarios. The system is deployed at <https://huggingface.co/spaces/prakashanusha/cybersecurity-guardian> and released under the MIT license.

References

1. Apache Software Foundation. (2021). CVE-2021-44228: Apache Log4j2 JNDI features do not protect against attacker-controlled LDAP and other JNDI related endpoints. <https://logging.apache.org/log4j/2.x/security.html>
2. Cybersecurity and Infrastructure Security Agency. (2026). Known exploited vulnerabilities catalog. <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
3. Es, S., James, J., Espinosa-Anke, L., & Schockaert, S. (2023). RAGAS: Automated evaluation of retrieval augmented generation. arXiv. <https://doi.org/10.48550/arXiv.2309.15217>
4. FBI Internet Crime Complaint Center. (2023). 2023 internet crime report. Federal Bureau of Investigation. https://www.ic3.gov/Media/PDF/AnnualReport/2023_IC3Report.pdf
5. LangChain. (2024). LangGraph documentation. <https://langchain-ai.github.io/langgraph>
6. National Institute of Standards and Technology. (2026). National vulnerability database. <https://nvd.nist.gov>
7. OpenAI. (2024). GPT-4o mini: Advancing cost-efficient intelligence. <https://openai.com/index/gpt-4o-mini-advancing-cost-efficient-intelligence>

8. PhishTank. (2026). PhishTank developer information. https://www.phishtank.com/developer_info.php
9. Pinecone. (2024). Pinecone serverless documentation. <https://docs.pinecone.io>
10. Reimers, N., & Gurevych, I. (2019). Sentence-BERT: Sentence embeddings using siamese BERT-networks. arXiv. <https://doi.org/10.48550/arXiv.1908.10084>
11. Streamlit. (2024). Streamlit documentation. <https://docs.streamlit.io>
12. VirusTotal. (2026). VirusTotal API v3 documentation. <https://developers.virustotal.com/reference/overview>

License

MIT License. Copyright (c) 2026 Anusha Prakash. Permission is hereby granted, free of charge, to any person obtaining a copy of this software and associated documentation files, to deal in the Software without restriction, including without limitation the rights to use, copy, modify, merge, publish, distribute, sublicense, and/or sell copies of the Software, and to permit persons to whom the Software is furnished to do so, subject to the following conditions: The above copyright notice and this permission notice shall be included in all copies or substantial portions of the Software.

Review History

CRITIQ Peer Review: 6 findings (1 Critical, 2 Major, 3 Minor). All findings addressed. Key changes: Abstract and Conclusion revised to lead with live evaluation results; inline scope notes added beneath mock-mode tables; thesis reframed as design hypothesis with baseline comparison named as Tier 1 future work; Section 6.4 restructured into three paragraphs; rate-limit timeout named as operational finding.

Bacon Diagnostic Scan: Paper readiness score: 4/5. Eight citation gaps identified all addressed with APA in-text citations in this version. Three blockers identified: VirusTotal evaluation external validity (addressed in Section 6.4 framing), absent baseline comparison (addressed - Section 6.8 added), absent user study (documented as future work in Section 8). APA in-text citation gap resolved throughout this version.

Changes made in response to Bacon diagnostic:

- APA in-text (Author, Year) citations added throughout all sections - 12 sources cited inline.
- Section 6.8 Baseline Comparison added directly addresses the unvalidated hypothesis flagged by Bacon and CRITIQ.

- Thesis reframed (Section 1.2) to accurately reflect what the baseline comparison demonstrates: evidence verifiability and novel-threat capability, not verdict accuracy superiority on known threats.
- Related Work section (Section 2) expanded with peer-reviewed citations on RAG accuracy, sentence transformer retrieval, and LLM cybersecurity applications.
- References reformatted to APA 7th edition with DOIs for arXiv preprints and retrieval URLs for web sources.